QAYRAWAN INFORMATION SYSTEMS

Cybersecurity Risk Management Methodology

ECC Compliance Program · Assess phase

Document ID	QIS-RMM-001
Version	0.2 (Draft)
Date	9 November 2026
Classification	Internal
Prepared by	Naif Alsalem, GRC Lead

Language. This document is issued in Arabic and English. In case of conflict, the Arabic text prevails.

Fictional case study. Qayrawan Information Systems (QIS), its people and its clients are invented for a professional portfolio. Any resemblance to a real organization is unintended. The regulators and frameworks named are real.

Document control

Role	Job title	Name	Status
Prepared by	GRC Lead	Naif Alsalem	Complete
Reviewed by	Cybersecurity Steering Committee	—	Pending
Approved by	Chief Executive Officer	Faisal Al-Harbi	Pending

Version history

Version	Date	Author	Change
0.1	7 Nov 2026	Naif Alsalem	First draft for review, translated from the Arabic lead text
0.2	9 Nov 2026	Naif Alsalem	Top risk level renamed "Catastrophic" (was "Critical")

Review cycle: Annually, or when QIS's scope of business or regulatory requirements change, or after a major incident.

1. Purpose and scope

This methodology sets how Qayrawan Information Systems identifies, analyzes, evaluates, treats and monitors cybersecurity risk, so that every risk is measured against the same criteria and treatment and acceptance decisions are made by the right authority.

It applies to the scope defined in the Company Profile and Scope (QIS-PRF-001): the three service lines, the Riyadh headquarters and Jeddah office, the systems QIS hosts, builds or manages for clients, staff and contractors, and third parties. Results are recorded in the Risk Register (QIS-RR-001).

2. References

Reference	Relevance to this methodology
Essential Cybersecurity Controls (ECC-2:2024), National Cybersecurity Authority	Requires a documented cybersecurity risk management methodology applied periodically.
ISO 31000, Risk management	The general framework for the risk management stages in section 4.
ISO/IEC 27005, Information security risk management	Guidance on identifying and analyzing risk at asset level.
QIS-PRF-001 Company Profile and Scope	Sets the context, scope and stakeholders.

3. Roles and responsibilities

Role	Responsibilities
Chief Executive Officer	Approves the methodology and risk appetite, decides on accepting high risks, and approves temporary acceptance of catastrophic risks.
Steering Committee	Reviews the risk profile quarterly, approves major treatment plans and their funding, and follows high and catastrophic risks monthly.
GRC Lead	Owns the methodology and the risk register, leads assessment sessions, checks assessments are consistent, and reports.
Risk owner	An executive who owns the risk, approves and delivers the treatment plan, and accepts low risks within their authority.
Cybersecurity team	Provides technical information on threats and vulnerabilities, operates technical controls, and measures their effectiveness.
All staff and contractors	Report potential risks and incidents as soon as they notice them.

4. Risk management stages

QIS follows seven stages that repeat in every assessment cycle.

#	Stage	Output
1	Establish context: scope, assets, stakeholders and regulatory requirements.	Company profile and scope; asset inventory.
2	Identify risks: what could happen, why, and with what consequence.	List of risks written as cause → event → consequence.
3	Analyze risks: estimate likelihood and impact given existing controls.	Likelihood, impact and score for each risk.
4	Evaluate risks: compare the score with risk levels and appetite.	Level and priority for each risk.
5	Treat risks: choose a strategy and prepare a treatment plan.	Treatment plan, owner and target date.
6	Monitor and review: follow treatment delivery and reassess.	Updated risk register.
7	Communicate and report: inform management and stakeholders.	Monthly and quarterly reports.

When assessments take place

- Annually for the full scope.
- Before launching a new system, taking on a new client, or making a major change to the technical architecture.
- After any major cybersecurity incident.
- When new regulatory requirements are issued or existing ones are updated.

5. Identifying risks

Risks are drawn from the asset inventory, gap assessment results, past incidents, threat intelligence and application threat modeling. Every risk is written in one format that links cause, event and consequence:

> **Because of** [the cause or weakness], **[the event] may happen**, **leading to** [the consequence for QIS or its clients].

Risks are grouped into these categories: governance; identity and access; applications; infrastructure and networks; devices; monitoring and response; continuity; third parties and cloud; people; and compliance.

Application threat modeling

STRIDE is applied to every application QIS builds or hosts that processes personal or confidential data, starting with Client A's citizen portal. The data flow is drawn, trust boundaries are marked, and each boundary is checked against the six categories: spoofing, tampering, repudiation, information disclosure, denial of service and elevation of privilege. Every untreated threat is recorded as a risk in the register.

6. Likelihood criteria

Score	Description	Criterion
5	Almost certain	Happening now, or expected more than once a year (over 80%).
4	Likely	Expected about once a year (50% to 80%).
3	Possible	Could happen within one to three years (20% to 50%).
2	Unlikely	Could happen within three to five years (5% to 20%).
1	Rare	Not expected within five years (under 5%).

Likelihood is estimated considering only existing, effective controls, not planned ones.

7. Impact criteria

Impact is estimated across five dimensions, and the highest rating among them is the risk's impact.

Score	Financial	Operational	Regulatory and contractual	Data and privacy	Reputation
5 Severe	Over SAR 10 million, or loss of a critical client contract	Critical services down for several clients for more than 3 days	Contract termination or a regulatory sanction	Large-scale leak of personal or classified data	National media coverage and loss of government trust
4 Major	SAR 2 million to 10 million	A critical service down for one client for 1 to 3 days	Regulator notice or contractual penalty	Limited leak of citizens' personal data	Formal complaint from a government client

Score	Financial	Operational	Regulatory and contractual	Data and privacy	Reputation
3 Moderate	SAR 500,000 to 2 million	One client down up to 24 hours, or several up to 4 hours	Significant finding in a client audit	Exposure of one client's confidential data	Client dissatisfaction needing senior management involvement
2 Limited	SAR 100,000 to 500,000	One client down up to 4 hours	Finding in an internal review	Exposure of limited internal data	Limited effect inside QIS
1 Minor	Under SAR 100,000	Minor disruption not affecting clients	None	No non-public data exposed	None

8. Risk matrix and levels

The risk score is likelihood multiplied by impact (1 to 25). The score sets the risk level using the matrix below.

5 Almost certain	**5**	**10**	**15**	**20**	**25**
4 Likely	**4**	**8**	**12**	**16**	**20**
3 Possible	**3**	**6**	**9**	**12**	**15**
2 Unlikely	**2**	**4**	**6**	**8**	**10**
1 Rare	**1**	**2**	**3**	**4**	**5**
Likelihood ↑ / Impact →	**1 Minor**	**2 Limited**	**3 Moderate**	**4 Major**	**5 Severe**

Very low	Low	Medium	High	Catastrophic
1 to 2	3 to 7	8 to 14	15 to 19	20 to 25

Where scores are equal, risks with higher impact come first, then risks affecting critical-tier clients.

9. Risk appetite and acceptance authority

QIS has a **low** appetite for risk affecting government clients' data and regulatory and contractual compliance, and a **moderate** appetite for internal operational risk that does not affect clients.

Level	Required action	Treatment starts within	Acceptance authority	Follow-up
Catastrophic (20 to 25)	Immediate treatment; permanent acceptance not allowed	30 days	CEO, temporary acceptance of up to 90 days with an approved plan	CEO informed within 24 hours; weekly follow-up
High (15 to 19)	Mandatory treatment	90 days	CEO through the Steering Committee	Monthly at the Steering Committee
Medium (8 to 14)	Treatment within the planning cycle	6 months	Executive risk owner with the GRC Lead	Quarterly
Low (3 to 7)	Treatment when resources allow	At the annual review	Risk owner	Annually
Very low (1 to 2)	Monitor only	—	Risk owner	Annually

Every risk acceptance is recorded on the risk acceptance form (Appendix A) and reassessed when it expires or circumstances change.

10. Treatment options

Strategy	When it is used	QIS example
Mitigate	When extra controls reduce likelihood or impact at a justified cost.	Enforce MFA on remote access (R-02).
Transfer	When another party can carry part of the financial or operational impact.	Contract a managed SOC; cyber insurance.
Avoid	When the risk outweighs the value of the activity causing it.	Stop using shared accounts altogether (R-01).
Accept	When the risk is within appetite or treatment costs more than the impact.	Accept a low risk on an isolated internal device until it is replaced.

11. Residual risk

Once a treatment plan is set, the target residual risk is estimated with the same criteria, assuming the plan is delivered on time. Residual risk must fall within appetite; otherwise the plan is revised or the risk is raised for an acceptance decision under section 9.

12. Monitoring and reporting

Report	Audience	Frequency	Content
Risk register update	GRC Lead and risk owners	Monthly	Treatment plan status, new risks and reassessments.

Report	Audience	Frequency	Content
Risk profile	Steering Committee	Quarterly	Heat map, top ten risks, overdue treatments, and key risk indicators.
Catastrophic risk alert	CEO	Within 24 hours of identification	The risk, its impact, and proposed immediate actions.
Annual report	CEO	Annually	Results of the full assessment and the fitness of the methodology.

13. Related documents

Document ID	Document
QIS-PRF-001	Company Profile and Scope
QIS-AST-001	Asset Inventory
QIS-RR-001	Risk Register
QIS-GAP-001	ECC Gap Assessment
QIS-RTP-001	Risk Treatment Plan

Appendix A. Risk acceptance form

Field	Required content
Risk ID and title	As in the risk register.
Current risk level	Likelihood, impact and score.
Reason for acceptance	Why treatment is not carried out now.
Compensating controls	What reduces the risk during the acceptance period.
Acceptance period	End date: at most one year, and 90 days for catastrophic risks.
Risk owner	Name, signature and date.
Accepting authority	Per section 9: name, signature and date.
GRC Lead	Confirms the form is complete and records it.